

Políticas de Seguridad

Data Loss Prevention (DLP)

1. Introducción al DLP

El Data Loss Prevention (DLP) es el conjunto de estrategias, procesos y tecnologías que una organización implementa para evitar que información confidencial salga de su perímetro de control — ya sea de forma accidental o intencionada.

En un entorno donde los datos son el principal activo, perder información sensible puede derivar en sanciones regulatorias, daño reputacional y pérdida de ventaja competitiva. El DLP actúa como red de seguridad: detecta, alerta y bloquea movimientos de datos que contravienen las políticas de la organización.

2. Clasificación de Datos

Toda la información generada o gestionada por la organización se enmarca en una de estas tres categorías:

Categoría	Ejemplos	Controles aplicados
Datos Públicos	Comunicados, web corporativa, catálogos	Sin restricciones
Datos Internos	Procedimientos, memos internos, reportes de gestión	Acceso para empleados autorizados
Datos Sensibles	Datos personales, financieros, propiedad intelectual, credenciales	Acceso estrictamente controlado + cifrado

El responsable de cada área asigna la categoría en el momento de crear o recibir la información. Ante la duda, se aplicará la categoría inmediatamente superior.

3. Acceso y Control

Principio de menor privilegio

Cada usuario accede únicamente a los datos que necesita para realizar su trabajo. El acceso se concede por rol, no por defecto.

- Las solicitudes de acceso deben estar aprobadas por el responsable directo y por el área de TI.
- Los permisos se revisan trimestralmente por el equipo de Seguridad junto con los líderes de área.
- Al producirse un cambio de rol o baja, los accesos se revocan en un plazo máximo de 24 horas.
- Los accesos de alto privilegio (administradores, sistemas críticos) requieren doble aprobación.

Flujo de revisión

Responsable de área → TI / Seguridad → Registro en sistema de gestión de accesos → Notificación al usuario.

4. Monitoreo y Auditoría

Se registra y monitorea de forma continua cualquier operación sobre datos sensibles e internos.

Herramientas utilizadas

- SIEM (ej. Microsoft Sentinel / Splunk): correlación de eventos y alertas en tiempo real.
- Solución DLP (ej. Microsoft Purview / Symantec DLP): control de flujo de datos en endpoints, correo y nube.
- Registros de auditoría en sistemas críticos: acceso, modificación y descarga de archivos sensibles.

Reglas de monitoreo

- Toda descarga o copia masiva de datos sensibles genera una alerta inmediata.
- Los intentos de acceso fuera de horario o desde ubicaciones no habituales son notificados al equipo de seguridad.
- Los registros se conservan un mínimo de 12 meses y se revisan mensualmente.

5. Prevención de Filtraciones

Se aplican controles técnicos en todos los canales de salida de información:

- Cifrado AES-256 en reposo para datos sensibles almacenados en servidores y dispositivos móviles corporativos.
- TLS 1.2 o superior en todas las comunicaciones en tránsito.
- La herramienta DLP bloquea el envío de datos sensibles por correo externo, almacenamiento cloud personal o dispositivos USB no autorizados.
- Está prohibido el uso de cuentas de correo personales o servicios de transferencia de archivos no aprobados para compartir información corporativa.
- Los equipos corporativos cuentan con cifrado de disco completo (BitLocker / FileVault).

6. Educación y Concientización

La tecnología no es suficiente sin personas capacitadas. Por eso el programa de formación contempla:

- Capacitación inicial obligatoria para todo el personal nuevo, que incluye esta política y los procedimientos básicos de seguridad.
- Sesión anual de actualización para todos los empleados, adaptada a los riesgos del año en curso.
- Simulacros de phishing periódicos con retroalimentación inmediata a quienes fallen la prueba.
- Canal de reporte de incidentes sencillo y accesible: cualquier empleado puede notificar una sospecha de filtración sin burocracia.